

04

Vulnerabilidades e Testes Éticos

Inventário, varredura, Nmap, Wireshark, Kali Linux, scanners e noções de pentest

Curso Técnico em Desenvolvimento de Sistemas

Capítulo planejado para aproximadamente 6 horas-aula

Material de apoio didático • teoria, laboratório e revisão

Base curricular

Este capítulo foi estruturado a partir das bases tecnológicas do componente Segurança de Sistemas de Informação do curso Técnico em Desenvolvimento de Sistemas do Centro Paula Souza. A coleção expande a ementa com exemplos e atividades de laboratório.

Objetivos de aprendizagem

- Diferenciar avaliação de vulnerabilidades de teste de penetração.
- Entender autorização, escopo, evidência e relatório em testes de segurança.
- Utilizar ferramentas de observação e inventário somente em laboratório autorizado.
- Classificar achados por contexto, impacto e prioridade de correção.

Alinhamento curricular

Alinha-se às bases de testes de penetração e vulnerabilidades e às ferramentas citadas na ementa, sempre dentro de escopo autorizado e finalidade educacional.

1. Vulnerabilidade não é sinônimo de invasão

Uma vulnerabilidade é uma fraqueza. Avaliação de vulnerabilidades busca descobrir e priorizar fraquezas; pentest tenta validar, em escopo controlado, se determinadas fraquezas podem resultar em impacto. O segundo é mais intrusivo e exige autorização explícita.

Em ambiente profissional, o documento de escopo define alvos, horários, técnicas permitidas, contatos, critérios de parada e tratamento de dados. Sem autorização, até uma varredura pode violar regras institucionais.

2. Inventário e enumeração defensiva

Antes de testar, é preciso saber o que existe. Inventário inclui hosts, serviços, versões, dependências, portas, domínios, APIs e responsáveis. A enumeração em laboratório ajuda a validar se a exposição observada corresponde ao desenho esperado.

Ferramentas como Nmap identificam portas e serviços. O resultado deve ser interpretado: porta aberta não é automaticamente vulnerabilidade; pode ser requisito legítimo. A pergunta correta é se o serviço deveria estar exposto, atualizado e protegido.

Exemplo seguro de laboratório

Uma varredura como “nmap -sV 127.0.0.1” pode ser usada no próprio computador para observar serviços locais. Em redes institucionais, use apenas se a atividade tiver autorização do responsável.

```
nmap -sV 127.0.0.1
```

```
# Interprete as portas abertas e associe-as a serviços conhecidos.
```

3. Wireshark e análise de tráfego

Wireshark captura e analisa pacotes visíveis na interface. Em laboratório, ele permite observar resolução DNS, conexões TCP, TLS e requisições em protocolos não criptografados. Em redes reais, captura pode envolver dados de terceiros e deve obedecer autorização e privacidade.

Um exercício útil é comparar tráfego HTTP sem TLS com HTTPS: o objetivo é compreender metadados visíveis e o que é protegido pela criptografia do transporte, sem tentar quebrar a sessão.

4. Scanners de vulnerabilidade

Scanners como Nessus ou alternativas equivalentes correlacionam serviços e configurações com bases de verificações conhecidas. Eles aceleram triagem, mas produzem falsos positivos, resultados dependentes de credenciais e achados que exigem validação humana.

Prioridade não deve depender apenas da pontuação técnica. Um serviço vulnerável isolado em laboratório pode representar menos risco que uma falha moderada em sistema público com dados sensíveis.

5. Kali Linux e frameworks de teste

Kali Linux reúne ferramentas de segurança para laboratórios e avaliações autorizadas. Metasploit é um framework de pesquisa e validação de vulnerabilidades. No curso, o foco deve ser compreender o fluxo de trabalho, nomenclatura e responsabilidade, evitando aplicar módulos ofensivos em sistemas de terceiros.

O fluxo profissional inclui autorização, descoberta, análise, validação controlada quando permitido, documentação de evidências, recomendação, reteste e encerramento.

6. Relatório técnico

Um bom relatório descreve ativo, evidência, risco, impacto, condição para reprodução, recomendação e prioridade. Ele evita exagero e separa fato observado de hipótese. Para públicos executivos, uma visão de risco e tendência pode ser mais útil que detalhes de ferramenta.

Reteste confirma se a correção realmente eliminou ou reduziu o risco sem introduzir regressões.

Laboratório e aplicação prática

Prática 4 - Inventário de serviços no próprio computador

Objetivo: Observar serviços locais e interpretar exposição sem atacar sistemas externos.

Regra de laboratório

Não faça varreduras, capturas ou testes contra equipamentos, sites ou redes sem autorização explícita. O exercício deve ficar restrito ao próprio computador ou a uma VM de laboratório.

1. Abra o terminal do seu sistema e liste conexões/portas locais com ferramenta nativa (por exemplo, netstat ou ss).
2. Em uma máquina de laboratório própria, execute uma varredura apenas contra localhost (127.0.0.1) ou uma VM deliberadamente criada para a aula.
3. Registre portas abertas e associe cada uma a um processo ou serviço conhecido.
4. Classifique cada porta como necessária, desconhecida ou candidata a desativação.

5. Produza uma recomendação de hardening e valide novamente após uma alteração segura.

Entrega sugerida: Uma tabela “porta → serviço → justificativa → ação”.

Questões de fixação

1. Qual é a diferença entre scanner de vulnerabilidades e pentest?
2. Por que uma porta aberta não é necessariamente uma vulnerabilidade?
3. Que informações mínimas devem existir em um escopo de teste?
4. Por que resultados de scanners precisam de validação humana?
5. O que deve constar em um relatório de vulnerabilidade útil para a equipe de desenvolvimento?

Como estudar

Responda primeiro sem consultar o texto. Depois compare sua resposta com o resumo do capítulo e complemente o que faltou.

Resumo do capítulo

- Testes de segurança dependem de autorização e escopo.
- Inventário vem antes da avaliação: não se protege o que não se conhece.
- Nmap e Wireshark são ferramentas de observação e diagnóstico que exigem uso responsável.
- Scanners aceleram triagem, mas não substituem análise de contexto.
- Relatórios claros e retestes transformam achados em melhoria efetiva.

Glossário essencial

Termo	Definição
Vulnerability assessment	Processo de identificar e priorizar vulnerabilidades.
Pentest	Teste de penetração autorizado para validar impacto de fraquezas.
Escopo	Limites técnicos e operacionais de um teste.
Enumeração	Levantamento de serviços e características de um alvo autorizado.
Falso positivo	Achado reportado como problema que, após validação, não se confirma.
Reteste	Nova verificação após correção.

Referências e materiais de consulta

- Centro Paula Souza. Plano de Curso do Técnico em Desenvolvimento de Sistemas, componente Segurança de Sistemas de Informação.
- CERT.br. Cartilha de Segurança para Internet. Conteúdo de conscientização e boas práticas de segurança.
- ISO/IEC 27001. Sistemas de gestão de segurança da informação - requisitos e princípios de gestão.
- OWASP Foundation. OWASP Top 10:2025 e materiais de segurança de aplicações web.